

Suite de Auditoría de Seguridad en Python

Guía de Desarrollo: Fase III - Aplicaciones Web y Reportes

Prof. César Rodríguez

Semanas 8 a 10

Resumen

El presente documento detalla los requerimientos teóricos y el flujo de trabajo colaborativo para los 4 grupos de desarrollo durante la **Fase III: Aplicaciones Web y Reportes**. Esta etapa final se apoya en los Capítulos 11 y 12 de nuestro texto guía, introduciendo conceptos ofensivos orientados a la capa de aplicación (HTTP/HTTPS) y culminando en la generación de reportes unificados.

1. Parte I: Fundamentos Teóricos por Grupo

Cada grupo debe investigar y dominar los siguientes conceptos teóricos antes de comenzar a codificar sus respectivos módulos.

Grupo 1: Rastreo y Mapeo Web (Crawler & Fuzzing)

- **Base literaria:** Capítulo 11 (Hackeo de Web / Descubrimiento y Mapeo).
- **Conceptos clave:** Comprender la arquitectura de un sitio web. El grupo desarrollará un "Spider" capaz de recorrer recursivamente los enlaces (`<a href>`), extraer información oculta en el código fuente (comentarios HTML, correos, scripts JS) y realizar descubrimiento de directorios ocultos (Fuzzing) utilizando diccionarios (ej. buscando `/admin`, `/respaldos.zip`).
- **Tecnología:** Librerías `requests` y `BeautifulSoup` (bs4) en Python. Expresiones Regulares (`re`) para la extracción de patrones de correo.

Grupo 2: Orquestación y Generación de Reportes

- **Base literaria:** Capítulos finales sobre Metodología y Presentación de Resultados.
- **Conceptos clave:** Consolidación de datos heterogéneos. El objetivo es estructurar la información recopilada por todos los módulos (Fases I, II y III) en un formato gerencial y técnico legible.

- **Tecnología:** Manejo avanzado de diccionarios JSON en Python. Librerías `csv` para reportes tabulares y manipulación de cadenas/plantillas (ej. Jinja2 o strings formateados) para generar archivos HTML dinámicos.

Grupo 3: Inyección de Código (SQLi)

- **Base literaria:** Capítulo 12 (Hacking de Web / Inyección de Bases de Datos).
- **Conceptos clave:** Inyección SQL (SQLi). El grupo debe estudiar cómo interactúan las aplicaciones web con el motor de base de datos de backend. Comprender el uso de caracteres especiales (como la comilla simple `'`) para romper la consulta SQL original e inyectar sentencias propias (ej. `' OR 1=1 --`).
- **Tecnología:** Librería `requests`, manejo de payloads y análisis de respuestas del servidor (búsqueda de errores de sintaxis SQL en el HTML).

Grupo 4: Vulnerabilidades Web (XSS y LFI/RFI)

- **Base literaria:** Capítulo 12 (Hacking de Web / Inyección y Fallos Lógicos).
- **Conceptos clave (XSS):** Cross-Site Scripting. Aprender cómo la falta de sanitización permite inyectar código JavaScript malicioso (ej. `<script>alert(1)</script>`) que se ejecuta en el navegador de la víctima.
- **Conceptos clave (LFI/RFI):** Local/Remote File Inclusion. Entender cómo los parámetros mal validados que cargan archivos (ej. `?page=index.php`) pueden manipularse con "Directory Traversal" (`../../../../etc/passwd`) para exponer archivos internos del servidor.
- **Tecnología:** Librería `requests`, manejo de parámetros GET/POST (Query Strings).

2. Parte II: Dinámica y Flujo de Trabajo

Esta fase repite la exitosa arquitectura de la Etapa II. **El desarrollo se hará de manera concurrente** apoyado en el Contrato de Datos.

- **Semanas 8 y 9:** Los Grupos 1, 3 y 4 deben construir sus Clases de Python en la carpeta `modulos/`. Deben probar sus scripts contra entornos seguros, como por ejemplo la máquina virtual *Metasploitable 2* o aplicaciones diseñadas para este fin como *DVWA* (*Damn Vulnerable Web App*).
- **Contrato de Datos Obligatorio:** Las funciones deben devolver exclusivamente diccionarios que cumplan con la estructura dictada en `schema_resultados.json`. Sin esto, la integración fallará estrepitosamente.
- **Semana 10 (Integración):** El Grupo 2 es el único autorizado para alterar `auditoria.py`. Ellos instanciarán las herramientas Web y las conectarán al flujo principal del orquestador, tomando la salida y guardándola en HTML y CSV.

Advertencia de Ética Profesional: Los escáneres de vulnerabilidades web generan mucho ruido y pueden alterar bases de datos o sistemas de archivos si no se manejan con cuidado. Solo deben apuntar sus scripts hacia plataformas locales de prueba o servidores que tengan autorización explícita y por escrito para ser auditados.

3. Parte III: Glosario de Términos

Crawler / Spider	Bot que navega por internet de forma sistemática y automatizada, leyendo y guardando el contenido de las páginas web y siguiendo sus enlaces internos.
Fuzzing	Técnica de prueba de software que consiste en inyectar datos inválidos, aleatorios o masivos (usando diccionarios) a una aplicación para descubrir fallos, fugas de memoria o, en el caso web, directorios y archivos ocultos.
Payload	En ciberseguridad, se refiere a la parte del código malicioso (o paquete de datos) que ejecuta la acción perjudicial. Por ejemplo, la cadena <code><script>alert(1)</script></code> es un payload común para XSS.
XSS (Cross-Site Scripting)	Vulnerabilidad que permite a un atacante inyectar scripts del lado del cliente en páginas web vistas por otros usuarios, robando típicamente cookies de sesión.

SQLi (SQL Injection) Fallo de seguridad que interfiere con las consultas que una aplicación realiza a su base de datos. Permite leer datos ocultos, modificarlos o incluso tomar el control del servidor subyacente.

LFI (Local File Inclusion) Vulnerabilidad que permite a un atacante incluir (y por lo tanto ejecutar o leer) archivos locales presentes en el servidor web.

Directory Traversal Subconjunto del LFI que consiste en usar secuencias como `../` (punto punto barra) para “escalar” fuera del directorio raíz web y acceder a archivos sensibles del sistema operativo.